

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 40

Simulate Cryptomining User Data Abuse and Validate GuardDuty Detection

Amazon EC2 | User Data | cloud-init | GuardDuty | Cryptocurrency Finding

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	July 30, 2026
STATUS	Complete

Executive Summary

Created a new **SLAW** CloudFormation stack using the existing public VPC template, launched an Amazon Linux EC2 instance, and used **cloud-init** user data to simulate a cryptomining-style callback. The user data ran a harmless **curl** command to a defunct mining-pool URL and redirected output to **/dev/null**, sending no mined data and installing no miner. GuardDuty detected the activity and generated a **CryptoCurrency:EC2/BitcoinTool.B!DNS** finding with **HIGH** severity in **us-west-2**. The EC2 instance and CloudFormation stack were deleted after validation.

DETECTION OUTCOME

This lab validates detective control coverage. User data can be abused to execute commands at launch, and GuardDuty detected the mining-related domain lookup generated by the test callback.

Business Problem

The prior lab showed that user data can expose secrets. This lab demonstrates the second major risk: user data can run commands automatically when an instance launches. An attacker with permission to launch instances could use cloud-init to bootstrap malware, backdoors, or cryptomining activity without using a custom malicious AMI. The objective was to simulate that behavior safely and verify that GuardDuty identified the suspicious mining-related domain activity.

Objectives

- * Create the SLAW CloudFormation stack using the provided public VPC template.
- * Launch an Amazon Linux EC2 instance in the public subnet.
- * Proceed without a key pair and use the default security group for the lab configuration.
- * Use user data and cloud-init to run a simulated cryptomining callback at first boot.
- * Use a defunct mining-pool URL and discard output to /dev/null so the test performs detection validation only.
- * Confirm GuardDuty detects the activity as a cryptocurrency-related EC2 finding.
- * Review the GuardDuty finding details, severity, type, region, and affected instance context.
- * Delete the instance and CloudFormation stack after validation to control cost and remove the lab exposure.

Environment

Cloud Provider	Amazon Web Services (AWS)
Primary Services	Amazon EC2, EC2 User Data, cloud-init, Amazon GuardDuty, AWS CloudFormation
Account Context	TestAccount1 / AdministratorAccess
Stack Name	SLAW

Template Source	Provided public VPC CloudFormation template
Instance OS	Amazon Linux 2023 shown in GuardDuty finding evidence
Instance Type	t2.micro shown in GuardDuty finding evidence
Availability Zone	us-west-2a shown in GuardDuty finding evidence
User Data Pattern	cloud-config runcmd with curl to defunct mining-pool URL and output redirected to /dev/null
Detection	GuardDuty CryptoCurrency:EC2/BitcoinTool.B!DNS
Severity	HIGH
Cleanup	Deleted EC2 instance and CloudFormation stack after detection validation

Architecture

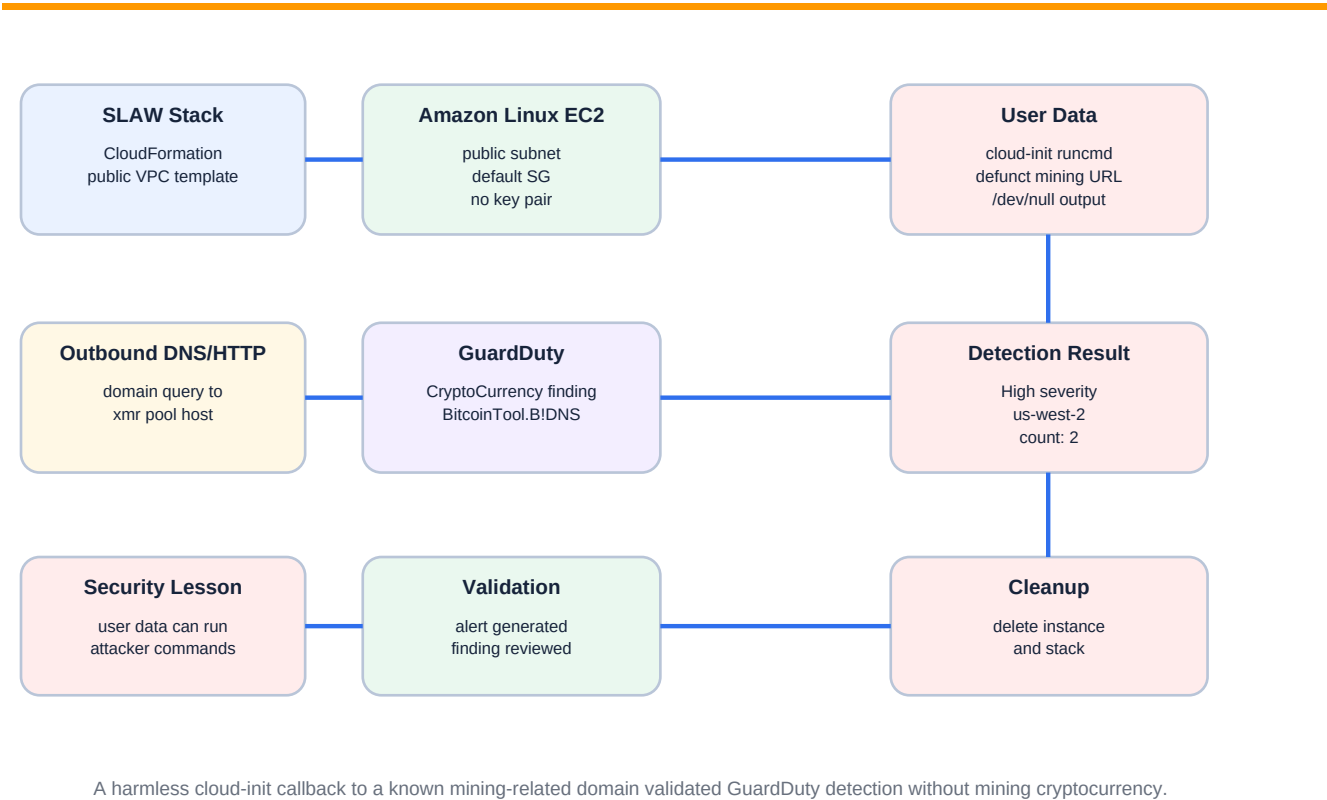


Figure 1 - User-data cryptomining simulation and GuardDuty detection flow.

Implementation Summary

1. Signed into TestAccount1 with AdministratorAccess.
2. Created a new CloudFormation stack named SLAW from the provided template.

- 3. Opened EC2 and launched a new Amazon Linux instance in the template-created VPC.
- 4. Configured the instance without a key pair and placed it in the default security group as a lab-only configuration.
- 5. Added cloud-init user data that runs a curl command to a defunct mining-pool URL and redirects output to /dev/null.
- 6. Launched the instance and allowed cloud-init to run at first boot.
- 7. Observed GuardDuty generate a cryptocurrency-related finding for the affected EC2 instance.
- 8. Reviewed the finding details: type, severity, region, affected resource role, instance type, state, and launch context.
- 9. Deleted the EC2 instance and CloudFormation stack after the detection was validated.

Embedded User Data

```
#cloud-config
runcmd:
  - "curl -s http://xmr.pool.minergate.com/dhdhjkhdkhdkhajkhjdjskahhkhjkaahdsjkakjasdhkjahdjk > /dev/null &"
```

This payload is documented as a controlled detection test. It initiates a connection to a mining-related domain and discards output. It does not install mining software or mine cryptocurrency.

Detection Map

User data execution	cloud-init runcmd executed at instance boot	Shows user data can run commands automatically when an instance launches.
Network callback	HTTP request to xmr.pool.minergate.com path	Creates a mining-related DNS/network indicator without mining.
GuardDuty type	CryptoCurrency:EC2/BitcoinTool.B!DNS	GuardDuty identified an EC2 instance querying a Bitcoin-related domain.
Severity	HIGH	Finding severity indicates high-priority investigation is appropriate.
Resource	EC2 instance in us-west-2a, t2.micro, running	GuardDuty tied the finding to the affected instance.
Cleanup	Instance and stack deleted	Removes exposure and avoids unnecessary lab cost.

Evidence

Figure 2 - Cloud-Init User Data Simulation Code

User data - optional | Info

Upload a file with your user data or enter it in the field.

Choose file

```
#cloud-config
runcmd:
- "curl -s http://xmr.pool.minergate.com/dhdhkhjdjkhjdjkhajkhdjskahjhkhjkaahdsjkakjasdhkjahdj > /dev/null &"
```

☐ User data has already been base64 encoded

Feedback

The EC2 launch evidence shows user data containing a cloud-config runcmd entry that runs curl against a defunct mining-pool URL and redirects output to /dev/null. This is the controlled simulation trigger for GuardDuty detection validation.

Figure 3 - GuardDuty Cryptomining Finding Generated

The EC2 instance [redacted] queried a Bitcoin-related domain name.

Automatically initiate a malware scan on the affected EC2 instance when GuardDuty detects findings like this one. [Learn more](#) Start 30-day free trial

High First seen 7 minutes ago, last seen 7 minutes ago Info

The EC2 instance [redacted] querying a domain name that is associated with Bitcoin-related activity.

[Investigate with Detective](#)

This finding is Useful Not useful

Overview

Finding ID	[redacted]	
Type	CryptoCurrency:EC2/BitcoinTool.BIDNS	
Severity	HIGH	
Region	us-west-2	
Count	2	
Account ID	[redacted]	
Resource ID	[redacted]	
Created at	07-30-2026 09:44:22 (4 minutes ago)	
Updated at	07-30-2026 09:44:24 (4 minutes ago)	

Malware scan (not enabled)

Scan status	Enable Malware Protection
-------------	---

Resource affected

Resource role	TARGET	
Resource type	Instance	

Instance details

Instance ID	[redacted]	
Instance type	t2.micro	
Instance state	running	
Availability zone	us-west-2a	
Image ID	[redacted]	
Image description	Amazon Linux 2023 AMI 2023.12.20260727.0 x86_64 HVM kernel-6.18	
Launch time	07-30-2026 09:40:52	

IAM instance profile

ARN	[redacted]	
ID	[redacted]	

Instance tags

--	--	--

The GuardDuty evidence shows a HIGH severity finding where the EC2 instance queried a Bitcoin-related domain. The finding type is CryptoCurrency:EC2/BitcoinTool.BIDNS, region is us-west-2, count is 2, resource type is Instance, instance type is t2.micro, and the instance state is running. Sensitive account, finding, resource, and profile identifiers are redacted.

Security Analysis

User data is a powerful bootstrapping mechanism. It can be used by administrators for legitimate configuration, but the same mechanism can be abused by attackers who have permission to launch or modify instances.

This lab uses a standard Amazon Linux instance rather than a malicious AMI. That is realistic because attackers may prefer an approved base image and use user data to pull commands or tools at runtime.

GuardDuty detected the mining-related domain activity as `CryptoCurrency:EC2/BitcoinTool.B!DNS`. This validates that the threat-detection pipeline can identify known cryptomining infrastructure indicators.

The test did not mine cryptocurrency. It only initiated a harmless callback to a defunct mining-pool URL and discarded output, which is enough to validate the detection path.

CloudTrail does not expose full user-data content in an easy monitoring form, so detection often depends on downstream runtime signals such as DNS queries, network behavior, EDR, or GuardDuty findings.

Deleting the instance and stack after validation is required because public test infrastructure and EC2 resources should not remain running longer than necessary.

Lessons Learned

Cloud-init runs commands when supported cloud instances launch for the first time.

Anyone with enough IAM privilege to run an instance and provide user data can potentially run arbitrary startup commands.

Cryptomining is a common abuse case for cloud-init/user-data compromise paths.

GuardDuty can detect mining-related DNS/domain activity from EC2 instances.

Private subnet design without Internet egress can reduce mining and botnet abuse opportunities, but attackers may still look for alternate paths.

Defensive validation labs should clean up resources immediately after confirming detection.

Production Improvements

- * Restrict `ec2:RunInstances`, `ec2:ModifyInstanceAttribute`, and `iam:PassRole` to approved roles and automation paths.
- * Use service control policies or permission boundaries to limit who can pass user data or launch Internet-routable instances.
- * Scan launch templates, CloudFormation templates, and user data for suspicious commands or URLs.
- * Require IMDSv2 and enforce least-privilege instance profiles.
- * Use private subnets and VPC endpoints where possible; avoid default public egress for workloads that do not need it.
- * Monitor GuardDuty cryptocurrency findings and route them through Security Hub/EventBridge to ticketing or notification workflows.

- * Enable VPC Flow Logs and DNS query logging for additional investigation context.
- * Define an incident runbook: isolate instance, snapshot evidence, preserve user data if needed, rotate credentials, and terminate/rebuild.

Skills Demonstrated

Amazon EC2	cloud-init / user data	Amazon GuardDuty
Cryptomining indicator	DNS/domain finding analysis	CloudFormation cleanup
Incident-response thinking	Least-privilege recommendations	Cost-control discipline

Resume Bullet

RESUME	Simulated a cloud-init based cryptomining callback through EC2 user data, validated Amazon GuardDuty detection with a HIGH severity CryptoCurrency:EC2/BitcoinTool.B!DNS finding, analyzed affected instance context, and removed lab infrastructure after validation.
--------	--

STAR Interview Story

Situation: The portfolio had already shown user data secret exposure, but the next risk was user data executing attacker-controlled commands at instance launch.

Task: Safely simulate a cryptomining-style user-data abuse path and validate that GuardDuty detected the activity.

Action: I created the SLAW stack, launched an Amazon Linux instance with cloud-init user data that called a defunct mining-pool URL and sent output to /dev/null, waited for GuardDuty detection, reviewed the HIGH severity CryptoCurrency finding, and deleted the instance and stack.

Result: The lab validated the detection pipeline for user-data-driven cryptomining indicators and documented production controls to reduce this attack path.

Version History

v1.0.0	July 30, 2026	Initial documented implementation. Created SLAW stack, launched EC2 instance with cloud-init user data callback to a defunct mining-related domain, validated GuardDuty CryptoCurrency:EC2/BitcoinTool.B!DNS finding, deleted instance and stack, and embedded provided evidence using portfolio documentation standard v1.0.1.

References

- * Cloud Security Lab a Week (S.L.A.W.) - Simulate an Attacker Mining Crypto with User Data.

- * User-provided cloud-init user data evidence screenshot.
- * User-provided GuardDuty cryptocurrency finding evidence screenshot.
- * Project 39 - Explore EC2 User Data Secret Exposure.
- * Project 36 - Deploy a Controlled Public SSH Exposure for GuardDuty Detection.